Monthly Intelligence Dispatch

July 2019

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specialises in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- In July 2019, Silence, a hacking group, used a new tool called **EmpireDNSAgent**, or EDA, to launch attacks on banks in Chile, Costa Rica, and Bulgaria.
- CloudMid spyware, which infected Russian healthcare organisations, was disguised as a VPN application purporting to be from **Informzashchita**, a Russian systems integrator.
- Winnti, a China-linked APT group, attacked German companies **BASF**, **Siemens**, and **Henkel**.
- Group-IB specialists detected several servers where the CobaltSrike framework was installed.
- OilRig, a pro-Iranian hacking group, is attacking its targets through LinkedIn.
- Group-IB's Threat Intelligence experts discovered a major leak of Sephora customers' data.
- The source code of a Linux bot called Lsbot was put up for sale on an underground forum.
- The Cerberus banking Trojan was put up for rent in a post on an underground forum.
- Austin Thompson (also known as DerpTrolling) was sentenced to 27 months in prison for organising Christmas DDoS attacks.

CloudMid

On 18 July 2019, media outlets reported about targeted attacks on Russian healthcare organisations using CloudMid spyware. The threat was detected by Kaspersky Lab, which said up to ten government agencies in Southern Russia were attacked in the spring and early summer of 2019. Group-IB's Threat Intelligence system had tracked the activity of CloudMid earlier: preparations for the attack started in January 2019 and the first malicious file was assembled and uploaded to VirusTotal on 1 February 2019. The malware was disguised as a VPN application purporting to be from Informzashchita, a Russian systems integrator, and covertly uploaded all of victims' documents, tables, and PDF files located in the Downloads and Desktop folders. Unlike widely used Trojan spyware, CloudMid turned out to be a primitive program with no protection against dynamic analysis, code obfuscation in particular. It is not designed to search for specific financial or other confidential information and collects all documents it can detect based on file type (.doc, .pdf, and .xlsx). The malware communicates with the C&C server via open channels without encryption or any other techniques of data concealment. The program does not ensure persistence in an infected system and is not capable of working in the background. It searches for and sends files only while it is open and stops once the window is closed.

Major events: espionage, sabotage, leaks

Winnti	**BASF, Siemens, Henkel** and other German companies experienced a new wave of cyberattacks linked to the Chinese APT group Winnti. Siemens, Henkel, and Roche explicitly stated that Winnti was involved in the infections, while BASF and Coverstro only confirmed they had been subjects of cyberattacks. In their recent investigation into an attack on Bayer, a pharmaceutical company, in April 2019, experts at **Chronicle** discovered a Linux variant of the backdoor hackers linked to Winnti use. The experts believe there are several APT groups operating under the Winnti umbrella, including Winnti, Gref, PlayfullDragon, APT17, DepositDog, Axiom, BARIUM, LEAD, PassCV, Wicked Panda, and ShadowPad. The groups show similar tactics, techniques, and procedures (TTPs) and in some cases share portions of the same hacking infrastructure.
APT15	Another China-linked cyberespionage group called APT15 (also known as Ke3chang, Mirage, Vixen Panda, Royal APT, and Playful Dragon) has been using **Okrum**, a previously unknown backdoor, for over two years, researchers at ESET report. In particular, the backdoor targeted diplomatic missions in Slovakia, Belgium, Chile, Guatemala, and Brazil throughout 2017. The hackers leverage the Okrum backdoor to deliver the **Ketrican** malware. The experts noted that the entities where they detected Okrum in 2017 had previously been infected with other malware attributed to APT15, which suggests that Okrum is the work of the same threat actor.
SyTech	In late July 2019, a number of media outlets reported that SyTech, a Moscow-based company, had been hacked. On 13 July, attackers breached SyTech's Active Directory server, from where they gained access to the company's entire IT network. The hackers stole 7.5TB of data and defaced the company's website. The documents received by BBC Russia reveal that the company has been involved in at least 20 non-public IT projects commissioned by Russian special service agencies and departments.

Major events: espionage, sabotage, leaks

OilRig	The Iran-linked APT34 group (also known as OilRig and HelixKitten) conducted a cyberespionage campaign attacking their victims via **LinkedIn**. The hackers disguised themselves as a member of Cambridge University, asked the victims to add them to their connections, and sent them messages with a malicious attachment, experts at **FireEye** report. APT OilRig has been active since around 2015 and primarily targets organisations in the financial, government, energy, and chemical sectors in the United States and the Middle East. As we predicted earlier, the group continued its attacks after a short lull despite leaked data on state-sponsored Iranian hacking groups.
StrongPity	Experts at **AT & T Alien Labs** have recently identified a new campaign conducted by StrongPity, an APT group that uses **WinBox** to infect their victims. StrongPity deploys malicious versions of WinBox router administration software, WinRAR, and other software to compromise their targets. StrongPity was first discovered in 2016. It created malicious websites to infect users in Europe, the Middle East, and North Africa.
Turla APT	**Turla APT** (also known as Snake, Uroburos, Waterbug) used new variants of the **KopiLuwak** Trojan in its targeted attacks in 2019, Kaspersky Lab reports. In their earlier attacks on EU diplomats, **Turla APT** used **PowerShell** scripts and a complex backdoor called **LightNeuron**. Since 2007, Turla has been attacking both government organisations and private businesses. Their list of victims includes the Swiss defence firm RUAG, the US Department of State, and the US Central Command.

Silence

In late July 2019, Group-IB specialists observed new attacks carried out by Silence against banks in **Chile**, **Costa Rica**, and **Bulgaria**. The attacks involved a new tool, which is downloaded by the main Trojan **Silence.Main** and based on the **Empire** and **dnscat2** open source projects for penetration testing. The tool was named **EmpireDNSAgent** or **EDA**. To control compromised systems the hackers used a server they configured not later than 6 July 2019. To transfer data, they used a legitimate DNS server of a hospital in Europe. Silence is becoming one of the most active and aggressive financially motivated hacking groups. In June 2019, Group-IB reported that Silence hackers were likely behind the attack on Dutch-Bangla Bank, in which at least $3 million was stolen. This is one of Silence's latest international attacks, which suggests the group has expanded its geography focusing on the APAC region.

CobaltSrike

Group-IB specialists detected several servers where the CobaltSrike framework was installed. In mid-June 2019, the domain *gryphonfinancial[.]net*, which was disguised as the company Gryphon Financial Group Inc, started pointing to one of these servers. The experts believe that there may be targeted attacks on financial organisations carried out under the name of Gryphon Financial Group Inc. Prior to that, the domain referred to another host, where the certificate of *alaskomega[.]ch* was detected. This indicates that the company AlaskOmega may have been attacked. Another server was linked to the domains *lccards[.]xyz* and *icscards[.]gq*, which affect the brand of International Card Services. Group-IB specialists believe there may be attacks on financial organisations carried out under the name of International Card Services. The group behind the preparations for the attacks have not yet been identified.

Sephora

Group-IB's Threat Intelligence experts discovered a data leak affecting the customers of Sephora, a chain of personal care and beauty stores (part of Louis Vuitton Moet Hennessy (LVMH) conglomerate since 1997). The first Sephora database was published on two hacker forums on 6 and 17 July 2019. It contains **500,000** entries, including user names and hashed passwords for *Sephora.co.id* (Indonesia) and *Sephora.co.th* (Thailand). The second database was discovered by **Group-IB's Threat Intelligence** team on an underground forum on 28 July 2019 and contains **3.2 million** entries, which were likely leaked in March 2019. The data contained in the leaks include logins, hashed passwords, registration dates, last active dates, IP registration, last IP, sex, first name, last name, ethnicity, eye colour, skin colour, skin type, hair colour, hair problems, etc. The leaks are sold at **$1,900**. Even though the leaks do not contain any payment information or decrypted passwords, they can be used in spear-phishing attacks with social engineering techniques.

British Airways

The U.K.'s Information Commissioner (ICO) fined British Airways £183,000,000 in connection with a customer data breach. In September 2018, British Airways reported that data of their website and mobile application users had been compromised. All users who booked tickets using the official website or app between 21 August and 5 September 2018 were affected, which amounted to about 500,000 people. Even though the information on the customers' passports and trip details had not been compromised, their personal and financial data ended up in the hands of unknown threat actors.

MyDoom	Experts at Palo Alto Networks have reported that the MyDoom worm (also known as Novarg, Mimail, and Shimg) is active. MyDoom, which appeared in 2004, is distributed through emails with malicious attachments. On a newly infected machine, the malware searches for new email addresses and sends copies of itself to all discovered addresses. The worm is notorious for incidents in which it paralysed Google, Yahoo! and AltaVista search engines. At its most active, MyDoom accounted for 16-25% of all malicious emails in the world. In 2011, McAfee experts estimated damages from MyDoom at $38 million.

Major events: malware

Lsbot

A user named SebastianPareiro made a post on **Exploit**, an underground forum, about selling the source code of the Linux bot LsBot. LsBot malware, which is written in C, is designed for Linux and works on different Linux distributions. The seller specified that they were selling two copies, because one of their clients disappeared. This indirectly indicates that the malware has already been used by unknown threat actors for some time. The price of the source code is **$8,000**, but the seller does not allow the bot to be used for mass targeting and in post-Soviet states. After the post was published, a user, who has been registered on the forum since 2010, wrote that they knew the team of LsBot developers and did beta testing of the product. The user said the bot had all the functionality stated in the post and that its performance was excellent. Interestingly, the same seller put on sale Clean-COW, a modified version of the Dirty COW exploit. The difference is that the modified version does not freeze and only takes five seconds to execute. The price of the Clean-COW source code is $3,000.

Cerberus

A user named ANDROID made a post on xss.is, an underground forum, about renting out the Cerberus banking Trojan. The malware can log keystrokes, retrieve emails and contacts, covertly intercept, send and delete SMS messages, send USSD requests, redirect calls, open fake banking webpages, and collect saved bank card details. The author of the post claims the malware works on Android version 5 and later. Operators of the bot cannot, however, infect devices that have phone numbers registered in post-Soviet countries. A monthly subscription to use the bot is $2,000. The price for one year is $12,000.

Arrests and sentences

Thompson

Austin Thompson (also known as DerpTrolling), a 23-year-old hacker who in 2014 created a trend of launching DDoS attacks against gaming services during Christmas, was sentenced to 27 months in prison and ordered to pay $95,000 in restitution. DerpTrolling took down gaming services **Sony PlayStation Network, Valve's Steam,** and **Microsoft Xbox** by carrying out large-scale DDoS attacks against them. In 2014, such attacks were launched by Lizard Squad, with Phantom Squad and R.I.U. Star Patrol following suit in 2015 and 2016. The annual trend of DDoS attacks on gaming services during Christmas was eventually stopped by law enforcement agencies, who seized the domains of 15 DDoS-for-hire services in December.

Hutchins

On 26 July, US District Judge JP Stadtmueller sentenced the British security researcher Marcus Hutchings (also known as MalwareTech) to time served. In 2017, Hutchins helped stop the **WannaCry** ransomware outbreak. He was later arrested on charges of creating and distributing the **Kronos** banking Trojan and **UPAS Kit** malware. Hutchins could face up to ten years in prison, two of which he has served.

Telegram

Four hackers have been arrested in Brazil on suspicion of breaking into more than 1,000 Telegram accounts, including some owned by high-ranking Brazilian government officials, such as Brazil's President **Jair Bolsonaro**, Justice Minister **Sergio Moro**, and Economy Minister **Paulo Guedes**. Other lower-ranking politicians, such as congresswoman **Joice Hasselmann**, also claimed to have been targeted. Local media reported that the hackers used access to the accounts to send spam messages with malicious links to the users' contacts. The group also appears to have targeted and hijacked accounts of local politicians, from where they are believed to have exfiltrated personal messages.

Arrests and sentences

Thompson

Paige A. Thompson, a 33-year-old resident of Seattle and a former Amazon Web Services employee, has been arrested on suspicion of stealing information about the customers of **Capital One**, a US bank. The breach, which occurred in March 2019, affected over **100 million** Americans and **six million** Canadians who applied for credit cards between 2005 and 2019. The information included names, addresses, zip codes/postal codes, phone numbers, email addresses, dates of birth, and self-reported income. Beyond the credit card application data, the individual also obtained portions of credit card customer data, such as credit scores, credit limits, balances, payment history, contact information, and fragments of transaction data from a total of 23 days during 2016, 2017 and 2018. Approximately one million Canadian social insurance numbers, 140,000 American social security numbers, and 80,000 bank account numbers were also accessed. The bank said that in order to hack into Capital One's network, the threat actor exploited a "configuration vulnerability", which was fixed on 19 July immediately after the breach was detected. The US Department of Justice said Thompson mentioned the compromise on GitHub and that the intrusion occurred through a misconfigured firewall. On 17 July 2019, a GitHub user who saw the post alerted Capital One to the possibility it had suffered a data theft. Thompson was eventually arrested. FBI agents searched her house and seized electronic storage devices containing a copy of the data stolen from Capital One.

Forecasts and warnings

- Silence is becoming one of the most active and aggressive financially motivated hacking groups. New Silence attacks can be expected in the APAC region. Imitators of the group are likely to operate in Russia and post-Soviet countries.
- Ransomware and spyware attacks on healthcare organisations will continue. Most of them will be more professional than the CloudMid attacks.
- The servers where the CobaltSrike framework was detected may be used in targeted attacks on financial organisations. The group behind the preparations for the attacks have not yet been identified.
- Even though the leaked data on 3.5 million Sephora customers do not contain any payment information or hashed passwords, they can be used in spear-phishing attacks with social engineering techniques.

If you wish to receive more detailed information about a specific incident, threat or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organisation.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com